

Access Control Policy

Mido Technologies | GRC Portfolio Artifact

1. Purpose

This policy establishes access-control requirements for the fictional Mido Technologies environment described in the WGU capstone. Its purpose is to reduce unauthorized access, improve user accountability, protect privileged accounts, and support consistent identity and access management practices.

2. Scope

This policy applies to users, administrative accounts, endpoints, network resources, business applications, email/collaboration services, and other systems within the simulated Mido Technologies environment.

3. Policy Statements

3.1 Unique user accounts

- Shared user accounts are prohibited where individual accounts can be supported.
- Each user must be assigned a unique account to support accountability.
- Account provisioning and lifecycle procedures must be documented and consistently followed.

3.2 Authentication and passwords

- Strong password requirements must be enforced for user accounts.
- Weak or reused credentials must be replaced.
- Administrative and other critical accounts must use multi-factor authentication (MFA) where supported.

3.3 Privileged access

- Administrative access must be limited to authorized personnel and used only when required.
- Privileged access should follow least-privilege principles.
- Access should be reviewed periodically to confirm that privileges remain appropriate.

3.4 Legacy systems and compensating controls

- When a legacy application cannot support MFA, the risk must be documented.
- Compensating controls may include network restrictions, enhanced logging, and regular access reviews.
- Critical applications, including email and financial systems, should receive priority when stronger authentication is deployed.

3.5 Network access

- Employee, guest, and IoT traffic must be logically separated using VLANs or equivalent segmentation.
- Access-control rules should restrict communication between network segments according to business need and least privilege.

3.6 Monitoring and accountability

- Authentication and security-relevant activity should be logged where technically feasible.
- Centralized logging should improve visibility into suspicious login activity and potential privilege escalation.
- Security events should be reviewed and escalated according to documented procedures.

4. Roles and Responsibilities

Role	Responsibility
Management	Support enforcement of access-control requirements and approve appropriate business access.
IT / Security Administrator	Provision and maintain accounts, enforce authentication controls, configure MFA, maintain logging, and perform access reviews.
Users	Use assigned credentials appropriately, follow password requirements, complete security training, and report suspected credential compromise.

5. Access Review and Account Lifecycle

Access should be reviewed periodically and when a user's responsibilities change. Accounts that are no longer required should be disabled or removed in a timely manner. Privileged access should receive additional scrutiny because compromise could create greater business impact.

6. Exceptions

Exceptions should be documented with the business or technical reason, associated risk, compensating controls, responsible owner, and planned remediation when applicable. The legacy-application MFA limitation identified during the capstone is an example of a condition requiring compensating controls rather than silent acceptance.

7. Compliance and Review

This policy should be reviewed periodically and after material changes to authentication systems, network architecture, or business applications. Violations or control gaps should be documented and remediated according to risk.

8. NIST CSF 2.0 Alignment

For portfolio purposes, this policy primarily supports NIST CSF 2.0 Identity Management, Authentication, and Access Control (PR.AA), with related support for Technology Infrastructure Resilience (PR.IR) and Continuous Monitoring (DE.CM). The formal CSF 2.0 mapping is a portfolio extension; the original capstone referenced NIST guidance and risk-to-control mapping.

Portfolio Disclosure

This policy was created as a GRC portfolio extension of an academic WGU capstone involving a fictional organization and simulated environment. It is not a policy issued by a real employer or client.